

Findings Register

System: Theraptly LMS (`lms2`) · **Audit date:** 2026-07-05 · **Branch audited:** `dev` @ `4f47527`

A flat, stable-ID list of every finding. Reference these IDs from tickets, PRs, and the other report tiers. Severity uses: **Critical** (exploitable data breach, compliance-blocking, or silent data loss), **High** (serious risk or scale-blocker), **Medium** (real but bounded), **Low** (hardening / hygiene).

Counts: **8 Critical** · **24 High** · **21 Medium** · **14 Low** (deduplicated across the eleven audit passes).

Critical

ID	Title	Area	Evidence	Fix summary
F-001	No audit trail anywhere in the system	Compliance / Audit	<code>prisma/audit.prisma</code> holds only <code>AuditorPack</code> (a report artifact) and it is never written; no <code>AuditLog</code> model exists; sensitive reads/writes go only to ephemeral stdout	Add an append-only <code>AuditLog</code> (actor, org, action, entity, ip, ts) written from a central helper on every auth event, PHI/PII access, export/download, role & billing change. Fails HIPAA §164.312(b).
F-002	PHI-scan bypass on the primary course-creation flow	AI / PHI	<code>src/app/actions/course-ai-v4.6.ts:501-512</code> extracts uploaded document text and sends it to Vertex AI with no <code>scanText</code> call; only the Document Hub path (<code>documents.ts</code>) scans	Run the fail-closed <code>scanText</code> gate before any generation call on the wizard upload path.
F-003	PHI transmitted to Google pre-verification and raw PHI values persisted	AI / PHI	<code>src/lib/documents/phiScanner.ts:50,75</code> sends first 15k chars to Gemini to <i>detect</i> PHI; matched strings stored in <code>phi_reports.detected_entities</code> (<code>documents.ts:135</code>)	Use a local/deterministic detector (regex + NER) or a BAA-covered DLP endpoint; store entity types/offsets , never raw values; execute + verify GCP BAA.
F-004	No database or object-store backups	Infrastructure	No <code>pg_dump</code> /WAL/snapshot tooling anywhere (grep of <code>scripts/db/docs/deploy</code>); all data on one VM's bind mounts <code>/home/deploy/data/*</code>	Scheduled encrypted Postgres backup (PITR) + object-store replication off-host; documented, tested restore runbook. HIPAA §164.308(a)(7).
F-005	Background workers & cron only start on a human page-load	Infrastructure / Jobs	Workers boot as import side-effects in <code>src/app/system/layout.tsx:47-71</code> (<code>force-dynamic</code> , <code>system-admin-gated</code>); no bootstrap in <code>src/instrumentation.ts</code>	After any restart, reminders/escalations, indexing, transcode, and sweeps silently never run until an admin opens <code>/system</code> . Move workers to an always-on process/service.
F-006	pgvector <code>embedding</code> column is invisible to Prisma → next migration drops it	Data	<code>manual_chunks.embedding</code> <code>vector(768)</code> added by raw SQL (<code>20260504100000_.../migration.sql:1</code>); absent from <code>prisma/category.prisma:42-44</code>	Model it as <code>Unsupported("vector(768)")</code> (or manage RAG store outside Prisma); mark as a protected column. A model-driven migration will <code>DROP</code> it today.

ID	Title	Area	Evidence	Fix summary
F-007	No DB-level tenant isolation; <code>Course / Enrollments</code> carry no <code>organizationId</code>	Data / Multi-tenancy	<code>course.prisma:28</code> , <code>enrollment.prisma:29</code> — org identity is transitive via <code>createdBy / user</code> ; no RLS, no scoping middleware	100% of tenant safety is per-query app code. Add <code>organizationId</code> + composite indexes, enforce Postgres RLS or a mandatory scoping layer in the new backend.
F-008	Google API key baked into the browser build	Infra / Secrets	<code>NEXT_PUBLIC_GEMINI_API_KEY</code> passed as a Docker build-arg (<code>Dockerfile:37,41</code> ; <code>deploy-*.yaml</code>); any <code>NEXT_PUBLIC_*</code> is world-readable	Currently unreferenced in <code>src/</code> so not bundled <i>today</i> , but the key is compiled into every image's env. Remove from all env/build files and rotate.

High

ID	Title	Area	Evidence	Fix summary
F-009	Cross-tenant IDOR: <code>getStaffDetails</code> reads any user's profile + enrollments + quiz history	Security	<code>src/app/actions/staff.ts:11-46</code> — session check only, no org scope (sibling mutations all check org)	Assert <code>target.organizationId === session.user.organizationId</code> + admin role before returning. CWE-639.
F-010	Cross-tenant IDOR: <code>getEnrollmentQuizResult</code> leaks answer keys + PII for any enrollment	Security	<code>src/app/actions/staff.ts:257-355</code> — no org scope; returns <code>correctAnswer</code> for every question + worker identity	Same fix: assert org match + role. CWE-639/200.
F-011	<code>xlsx@0.18.5</code> parses attacker-supplied spreadsheets (Prototype Pollution + ReDoS)	Security / Deps	<code>package.json</code> ; sinks <code>staff-csv.ts:162</code> , <code>onboarding/step4/page.tsx:91</code> , <code>auditor .../download/route.ts:148</code> . Fix (<code>>=0.20.2</code>) is not on npm	Migrate to SheetJS CDN build <code>^0.20.3</code> or <code>exceljs</code> ; validate + parse in an isolated worker with a size cap.
F-012	MFA is not enforced on API routes or server actions	Auth	A session cookie with <code>mfaVerified=false</code> is minted at credential sign-in (<code>create-auth-instance.ts:120</code>); the only MFA gate is in <code>proxy.ts:116-125</code> , whose matcher excludes all business API routes & actions	A password-only session can call <code>/api/billing</code> , <code>/api/quiz</code> , actions, etc. Enforce <code>mfaEnabled</code> → <code>mfaVerified</code> in a shared <code>requireSession()</code> used everywhere.
F-013	Business API routes bypass the auth proxy entirely	Auth	<code>proxy.ts:153-161</code> matcher covers only page routes; every <code>/api/**</code> handler self-guards with an imperative <code>auth()</code> call	Any handler that forgets the check is fully open (opt-in security). Add a default-deny wrapper.
F-014	Stripe webhook returns 200 on handler error and has no event-id idempotency	Billing	<code>src/app/api/webhooks/stripe/route.ts:69-73</code> returns <code>{received:true}</code> on exception → Stripe never retries; no <code>event.id</code> dedup, no out-of-order guard	Add <code>ProcessedWebhookEvent(id)</code> dedup, compare event timestamps, return 5xx for retryable failures.

ID	Title	Area	Evidence	Fix summary
F-015	BullMQ workers run inside the Next.js web process	Perf / Architecture	<code>system/layout.tsx:47-71</code> , <code>api/auditor/export/start/route.ts:105</code> , <code>api/system/worker/route.ts:23</code> ; <code>instances:2</code> in <code>ecosystem.config.js:43</code>	Central blocker to splitting web/worker; duplicate heavy consumers competing for the 4 GB heap. Extract to a standalone worker service.
F-016	Document parse + PHI scan + AI generation run synchronously in request handlers	Perf / AI	<code>documents.ts:31-53</code> (buffer + <code>pdf-parse / mammoth</code> + Vertex inline); <code>course-ai-v4.6.ts</code> awaits ~5 sequential Vertex calls via <code>after()</code> ; <code>quiz/[id]/submit</code> grades via Vertex inline	Prime source of the 4 GB heap need and multi-minute request slots. Offload to queued jobs with client polling.
F-017	No upload size limit on the main document/wizard paths; whole file buffered in memory	Perf / AI	<code>documents.ts:31</code> and <code>course-ai-v4.6.ts:505</code> read <code>file.arrayBuffer()</code> with no cap; only the manual route caps (50 MB)	OOM/DoS on large uploads. Enforce a cap and stream to storage; parse from storage in a worker.
F-018	No rate limiting on expensive AI endpoints	Security / Cost	No <code>checkRateLimit</code> in <code>course-ai*.ts</code> , <code>quiz-ai.ts</code> , or <code>quiz/[id]/submit</code> (grep)	An authenticated user drives unbounded Vertex cost / DoS. Add per-user/org quotas + concurrency caps.
F-019	No HTTP security headers (CSP, HSTS, X-Frame-Options, nosniff)	Security	<code>next.config.ts</code> has no <code>headers()</code> ; <code>lms2_nginx.conf</code> sets none	Clickjacking on the authenticated dashboard, no downgrade pinning, no CSP backstop for the rich-text surface. Add strict headers at Next or nginx. CWE-693/1021.
F-020	Failed reminder/escalation emails are marked "sent" and never retried	Email	<code>reminders/dispatch.ts:206-214</code> writes the dedup <code>ReminderLog(enrollment,stage)</code> row before sending; sender swallows transport errors (<code>email-sender.ts:148-160</code>)	A single SMTP failure permanently suppresses that compliance reminder. Record per-channel status; write dedup only after confirmed delivery; re-drive failures.
F-021	No email delivery-failure / bounce / suppression handling	Email	No <code>EmailMessage</code> model; fire-and-forget; every <code>email.ts</code> sender returns <code>{success:false}</code> without propagating	Add an <code>EmailMessage</code> table + retry queue + bounce ingestion.
F-022	Seat / plan limits never enforced after checkout	Billing	<code>staffMax</code> validated only at checkout against a free-text <code>organization.staffCount</code> (<code>checkout/route.ts:66-72</code>); nothing blocks inviting staff past the ceiling	Enforce seat limits at invite/accept against a live <code>count(users where role=worker)</code> .
F-023	hCaptcha / bot verification is not integrated despite being assumed present	Billing / Security	No <code>captcha / hcaptcha / turnstile</code> code or env anywhere; public POSTs rely on IP rate-limiting only	Add server-verified captcha on signup, request-demo, enterprise-inquiry, join flows.
F-024	Rate-limiter falls back to per-process in-memory state (fail-open across the fleet)	Security / Infra	<code>rate-limit.ts:13,78-91</code> uses a local <code>Map</code> on any Redis error; limits are per-instance	Multi-instance or Redis-down → limits multiply / reset. Fail-closed on limiter unavailability for auth paths; use a shared store with health gating.

ID	Title	Area	Evidence	Fix summary
F-025	No encryption at rest; document plaintext stored in the DB	Compliance / Infra	Plain <code>pgvector/pgvector:pg16</code> on host bind mount (<code>docker-compose.production.yml:65-72</code>); <code>DocumentVersion.content</code> holds extracted text (<code>document.prisma:25</code>); MinIO no SSE	Encrypted volumes / managed encrypted Postgres; MinIO SSE; drop or encrypt the <code>content</code> column; GCS CMEK. HIPAA §164.312(a)(2)(iv).
F-026	Broken Prisma singleton + no connection-pool tuning	Data / Perf	<code>db/index.ts:4-5</code> builds a new pool at import; <code>src/lib/prisma.ts:3-7</code> writes the global but never reads it back; <code>PrismaPg</code> gets no <code>max /timeout</code>	HMR/dev leaks pools; prod can exhaust Postgres connections. Collapse to one <code>globalForPrisma.prisma ?? new PrismaClient(...)</code> ; set pool limits + pooled/direct URLs.
F-027	Missing FK indexes on hot paths + no pgvector KNN index	Data / Perf	<code>lessons.course_id</code> (<code>course.prisma:111</code>), <code>questions.quiz_id</code> (<code>quiz.prisma:21-35</code>) unindexed; <code>rag.ts:65</code> does <code>ORDER BY embedding <=> \$q</code> with no <code>ivfflat / hns w</code> index	Sequential scans that worsen with growth. Add the FK indexes + an HNSW vector index.
F-028	Admin dashboard loads all enrollments into memory; several unbounded list queries	Perf	<code>course.ts:346-355</code> <code>include: { enrollments: true }</code> no <code>take</code> , aggregated in JS; <code>queue/page.tsx:7</code> , <code>documents/page.tsx:14</code> , auditor org export all unbounded	Multi-MB result sets per render. Use <code>groupBy / _count</code> ; paginate all growth-table reads.
F-029	Two conflicting deploy/runtime systems coexist (PM2 scripts + Docker/GHCR CI)	Infras truct ure	<code>deploy*.sh</code> + <code>ecosystem.config.js</code> (paths <code>/home/homepc/lms2*</code>) vs GH Actions Docker (<code>/home/deploy/apps/*</code>); CI actively <code>pm2 delete s</code>	Ambiguous production source of truth, high operator-error risk. Pick one mechanism; immutable image tags + documented rollback.
F-030	No CI security gates; e2e never runs in CI; heavy pre-commit pushes devs to <code>--no-verify</code>	Testi ng / Compliance	<code>ci.yml</code> has <code>lint/format/typecheck/test/build</code> but no <code>npm audit /SAST/secret-scan</code> ; <code>tests/e2e/**</code> excluded from vitest and not run; <code>.husky/pre-commit</code> runs full <code>test + build</code>	Add audit + secret-scan + Playwright jobs; move heavy checks to pre-push/CI; confirm branch protection.
F-031	Quiz scoring and multi-tenancy isolation have zero automated tests	Testi ng	No test for any <code>api/quiz/*</code> route (scoring at <code>submit/route.ts:154-165</code>); no cross-org negative test anywhere	The certification gate and the core tenant-safety property are unguarded. Add scoring unit/route tests + cross-org IDOR tests.
F-032	<code>QuizAttempt</code> schema cannot store attempt history	Data	<code>@@unique([enrollmentId, quizId])</code> (<code>quiz.prisma:49</code>) allows one row per enrollment/quiz, contradicting <code>attemptCount / allowedAttempts / retry</code> states	Attempts are overwritten. Drop/rework the unique to keep append-only history.

Medium

ID	Title	Area	Evidence	Fix summary
F-033	NextAuth credential callback bypasses login rate-limiting	Auth	Throttle lives in the <code>authenticate</code> action (<code>auth.ts:41</code>), not in <code>authorize()</code> (<code>create-auth-instance.ts:61</code>); raw <code>POST /api/auth/callback/credentials</code> skips it	Move throttle into <code>authorize()</code> or in front of the handler; add per-account lockout.
F-034	<code>course.ts</code> / <code>lesson.ts</code> mutators lack a role check	Auth	<code>createCourse/updateCourse/publishCourse/deleteCourse</code> (<code>course.ts:224-334</code>) and all <code>lesson.ts</code> check only <code>session.user.id</code> , scope by <code>createdBy</code>	A worker session can create courses; soft privilege boundary. Assert <code>role==='admin'</code> ; consider org-based ownership.
F-035	<code>AUTH_SECRET</code> vs <code>NEXTAUTH_SECRET</code> split-brain	Auth	<code>proxy.ts:48</code> decodes with <code>AUTH_SECRET</code> ; encoder + all other decoders use <code>NEXTAUTH_SECRET</code>	Same value today, but divergence silently logs everyone out. Standardize on one var.
F-036	JWT callback is fail-open on DB errors	Auth	<code>create-auth-instance.ts:317-325</code> preserves the token if revalidation throws	Deleted/role-changed users retain access during a DB outage. Document / add a short grace window + revocation epoch.
F-037	No rate limit on password-reset request or <code>POST /api/invite/accept</code>	Auth	<code>auth.ts:250</code> (reset) and <code>invite/accept/route.ts:18</code> have no throttle	Email-bombing / enumeration timing; account-creation spam. Add IP limits consistent with signup.
F-038	Public certificate verification page leaks recipient email	Certificates	<code>verify-certificate/[id]/page.tsx:79</code> renders <code>`profile?.fullName`</code>	
F-039	<code>`score: enrollment.score`</code>		<code>100`</code> truthiness bug on certificates	Certificates
F-040	Portal-initiated Stripe pause never expires	Billing	Webhook reconciles <code>pauseEndsAt: existing ?? null</code> (<code>webhooks/stripe/route.ts:134</code>); <code>null</code> → <code>getPauseState</code> returns <code>paused</code> forever (<code>billing.ts:35-44</code>)	Default a portal-originated pause to <code>now + MAX_PAUSE_MONTHS</code> .
F-041	<code>stripe</code> default export can be <code>null</code>	Billing	<code>stripe.ts:37-39</code> non-null-asserts a possibly-null client; <code>constructEvent</code> throws a raw <code>TypeError</code> if <code>STRIPE_SECRET_KEY</code> missing at import	Use the lazy <code>getStripeClient()</code> everywhere.
F-042	No central env validation at boot	Infra	No zod/invalid startup schema; every service reads <code>process.env</code> lazily with <code>`</code>	

ID	Title	Area	Evidence	Fix summary
F-043	nginx is bypassed by the Cloudflare tunnel	Infra	<code>cloudflared_config.yml:12-16</code> routes hostnames straight to <code>localhost:3000/3001</code> ; nginx <code>server_name lms.theraptly.com</code> $\neq$ prod host <code>training.theraptly.com</code>	nginx body-size limits, real-IP, timeouts, and (future) security headers never apply on the live path. One consistent ingress.
F-044	<code>minio/minio:latest</code> (and other floating tags) unpinned	Infra	<code>docker-compose.*.yml</code> use <code>minio/minio:latest</code>	Non-reproducible builds; surprise breaking upgrades on <code>docker compose pull</code> . Pin digests.
F-045	Reminder sweep is O(enrollments) with per-enrollment N+1 recipient queries	Perf	<code>reminders/sweep.ts:47</code> loops due enrollments; <code>recipients.ts:60</code> <code>user.findMany</code> per enrollment; sequential email awaits	Wall-clock scales linearly, can exceed the 25-min lock. Batch-resolve recipients; bounded-concurrency fan-out.
F-046	No caching layer anywhere	Perf	No <code>unstable_cache</code> /Redis GET-SET/ <code>setMaxAge</code> (<code>grep</code>); dashboard aggregations + RAG embeddings recomputed every request	Redis-cache expensive aggregations + embeddings; tag-based invalidation.
F-047	All video/media bytes proxied through the Next server	Perf / Scale	<code>api/video/[lessonId]/route.ts:79-99</code> , <code>preview-video/route.ts:77</code> stream storage bytes through the app	Hard scaling ceiling for video-heavy orgs. Serve via CDN / public signed URLs.
F-048	Verbose internal error returned to client from document proxy	Security	<code>documents/[versionId]/preview/route.ts:57</code> returns <code>Error proxying document: \${e.message}</code>	Leaks storage host/URL fragments. Return generic message; log details server-side. CWE-209.
F-049	Vertex safety filters all <code>BLOCK_NONE</code> + unescaped prompt-injection surface	AI / Security	<code>ai-client.ts:113-118</code> ; <code>untrusted {{DOCUMENT_TEXT}} / {{RAG_CONTEXT}}</code> interpolated raw (<code>prompts-v4.6.ts:625-651</code>); PHI prompt also interpolates untrusted text	A crafted document can steer generation or make the PHI scan report <code>hasPHI:false</code> . Delimit/escape input; reconsider <code>BLOCK_NONE</code> .
F-050	<code>String.replace(string, string)</code> prompt substitution corrupts on <code>\$&</code> , <code>\$`</code> , <code>\$'</code> , <code>\$\$</code>	AI	<code>prompts-v4.6.ts:625-672</code>	Document text containing <code>\$</code> -sequences injects/corrupts the prompt. Use a function replacer or <code>split/join</code> .
F-051	Generated courses auto-publish with no review gate even when stages degrade	AI / Content	Stages B-E are non-fatal and only emit warning strings (<code>course-ai-v4.6.ts:886-897</code>); <code>createFullCourse</code> sets <code>status:'published'</code> (<code>course.ts:694</code>)	Low-quality/missing-quiz courses go live. Require review / block publish when warnings exist.
F-052	Org-scoped category slug is globally unique	Data	<code>course_categories.slug @unique</code> (<code>category.prisma:9</code>) but categories can be org-scoped	Two orgs can't share a custom slug. Use <code>@@unique([organizationId, slug])</code> .
F-053	No unique on <code>enrollments</code> (<code>user_id</code> , <code>course_id</code>)	Data	<code>enrollment.prisma:57</code> only indexes, no unique	Duplicate active enrollments possible. Add a partial unique on active statuses.

ID	Title	Area	Evidence	Fix summary
F-054	Removed staff keep an active account; no retention/disposal policy	Compliance	<code>staff.ts:357-405</code> only nulls <code>organizationId</code> ; no purge jobs for <code>tokens/invites/ detected_entities</code> ; no user self-delete	Define retention windows + scheduled purge + a deactivation/deletion path. SOC 2 C1.2.
F-055	Transitive dependency CVEs unaddressed; no audit gate	Dependencies	<code>npm audit: @babel/core</code> , <code>postcss<8.5.10</code> (via next), <code>ajv</code> , <code>brace-expansion</code> , <code>uuid</code> , <code>quill@2.0.3</code> XSS (mitigated by <code>DOMPurify</code>)	Run <code>npm audit fix</code> for the safe set; evaluate forced bumps; add <code>npm audit /Dependabot</code> to CI.

Low

ID	Title	Area	Evidence
F-056	Weak system-admin auth: shared static password, non-constant-time <code>===</code> , no per-actor identity	Auth	<code>system-admin.ts:47</code> ; grants cross-org super-admin incl. <code>deleteUserWithRelations</code>
F-057	Email address leaked in forced-reset redirect URL	Auth	<code>proxy.ts:105</code> puts <code>email</code> in the query string
F-058	Inconsistent bcrypt cost factors (10 vs 12)	Auth	<code>auth.ts:200,313,357</code> vs <code>create-auth-instance.ts:178</code>
F-059	Password reset / forced reset does not invalidate existing sessions	Auth	No <code>sessionVersion</code> / <code>passwordChangedAt</code> claim checked in the jwt callback
F-060	Sensitive info committed in <code>.claude/agent-memory/*</code> (dev DB password, GCP SA email, test creds, defect notes)	Secrets	Git-tracked memory files
F-061	Two parallel job-polling implementations with divergent guarantees	Front end	Robust <code>use-job-status.ts</code> (1 consumer) vs ad-hoc <code>ExportJobsProvider.tsx:174</code> (<code>setInterval 1500</code> , <code>localStorage</code>)
F-062	Global toasts effectively broken outside the admin area	Front end	<code><Toaster></code> mounted only at <code>dashboard/(main)/layout.tsx:81</code> ; <code>worker/auth/onboarding/system toast()</code> calls no-op
F-063	84% of components are client components (114/135); heavy libs statically imported	Front end / Perf	<code>recharts</code> , <code>react-pdf</code> , <code>xlsx</code> not code-split; <code>learn/[id]/page.tsx</code> 1118 lines
F-064	No <code>error.tsx</code> boundaries; only one <code>loading.tsx</code>	Front end	0 error boundaries; server components do live DB I/O
F-065	Design-system drift: 78 files with raw hex in <code>className</code> , 26 with inline styles; two token sources	Front end	<code>globals.css @theme</code> vs <code>src/style/design-tokens.ts</code>

ID	Title	Area	Evidence
F-066	No timeout on embeddings AI call	AI	ai-client.ts:244 — generateBatchEmbeddings has no AbortController
F-067	No log shipping/retention/correlation IDs; serializeError may spread sensitive props	Observability	logger.ts:74-77 stdout only; :31-35 spreads all own error props
F-068	God files correlate with untested high-churn areas	Quality	course.ts 1,337 · email.ts 1,148 · learn/[id]/page.tsx 1,118 · course-ai-v4.6.ts 996
F-069	Stale docs mislead compliance review	Docs	docs/phi-redactor.md documents old fail-open + API-key auth (both contradict current code); docs/system-architecture.md still says "CSS Modules" and single-process

Verified-good (record for the rebuild — do not regress)

- The **12 prior security findings** in docs/hack-check.md are all genuinely fixed on dev (invite org/role from session, staff same-org mutations, CSPRNG tokens, org-code rate-limit, auditor download isolation).
- **PHI currently routes only through BAA-eligible Vertex AI** (OAuth service account); the consumer Gemini SDK (@google/generative-ai , non-BAA endpoint) is a declared dependency but **unreferenced in src/** . Keep it that way.
- **Parameterized SQL** everywhere (\$queryRaw / \$executeRawUnsafe all parameterized); **DOMPurify** on every dangerouslySetInnerHTML sink; **signed-URL** media proxies (no SSRF from user input); **Stripe signature verification**; secure cookie flags + separate admin/worker realms.
- **Zero console.*** outside the logger; **maskEmail** helper exists; strong unit coverage of lib/ pure logic (553 cases).
- **CSS-Module migration is genuinely complete** (0 .module.css).